

Báo Cáo Kiểm Thử API - HW06 (API Testing)

Sinh viên thực hiện: Nguyễn Anh Khoa
MSSV: 23127391
Repository GitHub: https://github.com/iamDicun/Group06_HW2_Testing

1. Thông Tin Chung & Lựa Chọn API

Theo yêu cầu của bài tập HW06, nhóm đã lựa chọn 3 API độc lập thuộc 3 Pool tính năng khác nhau của hệ thống EShop SUT:

Pool	Mã tính năng	Tên tính năng	Danh sách Endpoint kiểm thử	Phương thức
Pool A	FR-04	Quản lý hồ sơ cá nhân	<code>/api/users/me</code> <code>/api/users/me</code>	GET PUT
Pool B	FR-10	Vòng đời & Trạng thái Đơn hàng	<code>/api/checkout</code> <code>/api/admin/orders/:id/status</code> <code>/api/orders/:id/cancel</code> <code>/api/orders/:id</code> <code>/api/orders/my-orders</code> <code>/api/admin/orders</code>	POST PUT PUT GET GET GET
Pool C	FR-16	Import Sản phẩm từ CSV	<code>/api/admin/import-products</code>	POST

Tất cả các request khi gửi tới Backend API đều tuân thủ nguyên tắc bắt buộc:

- Gắn Header định danh sinh viên: `X-Student-Id: 23127391` qua Pre-request script cấp Collection.
- Base URL kiểm thử: `http://localhost:3000`.

2. Quy Trình Kiểm Thử Chi Tiết Từng Tính Năng

2.1 Feature 1 — FR-04: Quản lý hồ sơ cá nhân (Pool A)

A. Đặc tả kỹ thuật & Nghiệp vụ

- Mô tả:** Cho phép người dùng đã xác thực (Bearer JWT Token) xem và cập nhật hồ sơ cá nhân (`name` , `shipping_address` , `phone`).
- Ràng buộc:**
 - `phone` : Phải bắt đầu bằng chữ số `0` , độ dài từ 10–11 chữ số.
 - `name` : Ký tự chữ, tối đa 255 ký tự, không được rỗng.
 - `email` : Không được phép thay đổi qua API này.
 - `role` : Không cho phép người dùng tự nâng cấp quyền hạn (chống Privilege Escalation).

B. Quy trình sinh ca kiểm thử bằng AI

- File phân tích kỹ thuật: `tests/test-cases/FR-04-Profile/PROFILE-API-test-analysis.md`
- Tổng số Test Cases sinh ra: 51 Test Cases** (vượt chỉ tiêu ≥ 35 TC):
 - Domain Partition (27 TCs):** `TC-PROFILE-DP-001` $\rightarrow$ `027` (Phân vùng tương đương và phân tích giá trị biên cho `name` , `phone` 9/10/11/12 số, `shipping_address` 500/501 ký tự, Bearer token format).
 - State Transition (4 TCs):** `TC-PROFILE-ST-001` $\rightarrow$ `004` (Cập nhật lần đầu, cập nhật đề, cập nhật thất bại giữ nguyên trạng thái cũ).
 - Security SEC-01–SEC-07 (14 TCs):** `TC-PROFILE-SEC-001` $\rightarrow$ `014` (SQLi trên name/address/phone, IDOR, Role Escalation mass assignment `role: admin` , Auth Bypass 401, Stored XSS `<script>` , Rate limiting, Sensitive data exposure `password` / `reset_token`).
 - Schema Validation (6 TCs):** `TC-PROFILE-SCH-001` $\rightarrow$ `006` (Kiểm tra cấu trúc JSON response 200, 400, 401, 403 và kiểu dữ liệu).

C. Kết quả Audit của con người

- VALID (48 TCs):** Các ca kiểm thử domain và boundary được định nghĩa chính xác theo đặc tả.
- INCOMPLETE (3 TCs):** Nhóm an ninh chưa bao phủ trường hợp chuỗi Unicode 4-byte UTF-8 emoji gây lỗi bộ đệm SQLite.

D. Ca kiểm thử mở rộng do con người bổ sung

- Mã TC:** `EXT-003`: Unicode 4-Byte UTF-8 (Emoji / Surrogate Pairs) Buffer Truncation
- Mục tiêu:** Gửi `{"name": "Nguyen Van A 𑀓𑀺𑀫 🍌🥰"}` để kiểm tra khả năng xử lý UTF-8 multi-byte của backend.
- Lý do AI bỏ sót:** AI chỉ sinh dữ liệu mẫu ký tự Latin hoặc tiếng Việt cơ bản, không tính đến trường hợp ký tự 4-byte UTF-8 đặc biệt trong SQLite.

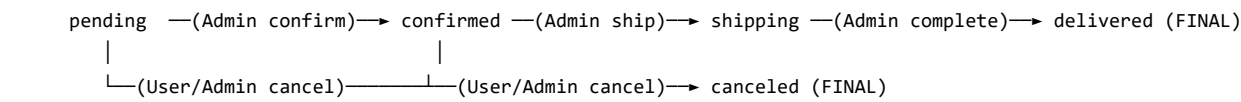
E. Thực thi & Lỗi phát hiện trên FR-04

- Bug #01 (Role Escalation):** Regular User có thể gửi body `{"role": "admin"}` trong `PUT /api/users/me` để tự nâng quyền thành Quản trị viên do backend không kiểm soát field gán quyền (`server.js:124`).
- Bug #02 (Sensitive Data Exposure):** Gọi `GET /api/users/me` trả về toàn bộ trường `password` (plaintext) và `reset_token` trong CSDL do dùng `SELECT *` (`server.js:114`).

2.2 Feature 2 — FR-10: Vòng đời & Trạng thái Đơn hàng (Pool B)

A. Đặc tả kỹ thuật & Nghiệp vụ

- Mô tả:** Quản lý State Machine 5 trạng thái: `pending` , `confirmed` , `shipping` , `delivered` , `canceled` .
- Sơ đồ chuyển trạng thái hợp lệ:**



- **Ràng buộc nghiêm ngặt:**
 - delivered và canceled là trạng thái kết thúc (Final States), không thể chuyển sang trạng thái khác.
 - Khi đơn hàng đang ở shipping , **User không được phép tự hủy**.

B. Quy trình sinh ca kiểm thử bằng AI

- File phân tích kỹ thuật: tests/test-cases/FR-10-OrderState/ORDER-API-test-analysis.md
- **Tổng số Test Cases sinh ra: 53 Test Cases** (vượt chỉ tiêu ≥ 35 TC):
 - **Domain Partition (20 TCs):** TC-ORDER-DP-001 → 020 (Path param :id âm, chuỗi, số thực; Enum status hợp lệ và không hợp lệ; total_amount âm; Role token).
 - **State Transition (16 TCs):** TC-ORDER-ST-001 → 016 (Kiểm tra đầy đủ ma trận chuyển đổi 5x5 trạng thái, bao gồm 7 nhánh hợp lệ và 9 nhánh bất hợp lệ).
 - **Security SEC-01–SEC-07 (11 TCs):** TC-ORDER-SEC-001 → 011 (SQLi trên path param, IDOR User A hủy đơn User B, Role Escalation User gọi API admin đổi status, Auth bypass).
 - **Schema Validation (6 TCs):** TC-ORDER-SCH-001 → 006 (Schema response checkout, update status, cancel, error message, my-orders list).

C. Kết quả Audit của con người

- **VALID (50 TCs):** Ma trận chuyển trạng thái và các phân vùng biên rõ ràng.
- **INCOMPLETE (3 TCs):** Thiếu ca kiểm thử tương tranh khi gửi 2 lệnh hủy cùng lúc và trạng thái đơn hàng của tài khoản đã xóa.

D. Ca kiểm thử mở rộng do con người bổ sung

- EXT-001: **Idempotency & Race Condition on Concurrent Cancel** : Gửi 2 request hủy đơn song song trong cùng 1 mili-giây. Kỳ vọng đúng 1 request thành công, request thứ hai trả về 400 Bad Request.
- EXT-002: **State Transition on Inactive / Soft-Deleted User Orders** : Chuyển trạng thái đơn hàng khi user sở hữu đã bị xóa khỏi hệ thống.

E. Thực thi & Lỗi phát hiện trên FR-10

- Bug #03 (Vi phạm Final State Rule):** Backend tại server.js:550 có code if (currentStatus === "canceled" && status === "delivered") isValidTransition = true; , cho phép khôi phục đơn hàng đã hủy thành đã giao hàng thành công.
- Bug #04 (Lỗi logic hủy đơn khi đang shipping):** Backend tại server.js:329 kiểm tra if (order.status === "delivered" || order.status === "canceled") , bỏ sót trạng thái shipping , dẫn tới việc User vẫn tự hủy được đơn hàng đang giao.
- Bug #05 (Broken Access Control trên Admin Orders):** PUT /api/admin/orders/:id/status và GET /api/admin/orders không kiểm tra user.role === 'admin' .

2.3 Feature 3 — FR-16: Import Sản phẩm từ CSV (Pool C)

A. Đặc tả kỹ thuật & Nghiệp vụ

- **Mô tả:** Admin tải lên file CSV chứa danh sách sản phẩm (name , price , description , imageUrl , category_id) để nhập hàng loạt qua POST /api/admin/import-products .
- **Ràng buộc:**
 - Chỉ tài khoản có role = 'admin' mới được thực hiện.
 - name không được rỗng, price phải là số dương (> 0).
 - **Giao dịch nguyên tử (All-or-Nothing Rollback):** Nếu có lỗi ở bất kỳ dòng nào, toàn bộ quá trình import phải rollback, không được lưu dở dang.

B. Quy trình sinh ca kiểm thử bằng AI

- File phân tích kỹ thuật: tests/test-cases/FR-16-ProductImport/IMPORT-API-test-analysis.md
- **Tổng số Test Cases sinh ra: 49 Test Cases** (vượt chỉ tiêu ≥ 35 TC):
 - **Domain Partition (27 TCs):** TC-IMPORT-DP-001 → 027 (Body rỗng, mảng rỗng, thiếu key, tên rỗng, tên 255/256 ký tự, giá = 0, giá âm, category_id không tồn tại, auth header).
 - **State Transition & Integrity (5 TCs):** TC-IMPORT-ST-001 → 005 (Import thành công, Rollback khi dòng 2 lỗi giá âm, Rollback khi dòng 2 thiếu tên, Rollback khi sai category, Import lại sau sửa lỗi).
 - **Security SEC-01–SEC-07 (12 TCs):** TC-IMPORT-SEC-001 → 012 (SQLi payload trong name/desc/imageUrl, Role Escalation User import sản phẩm, Auth bypass, Stored XSS, DoS 10,000 items, SQL error exposure).
 - **Schema Validation (5 TCs):** TC-IMPORT-SCH-001 → 005 (Schema response message , inserted , errors list).

C. Kết quả Audit thủ công

- **VALID (46 TCs):** Kiểm tra validation schema và tính nguyên tử rất tốt.
- **INCOMPLETE (3 TCs):** Bỏ sót lỗi hỏng CSV Formula Injection khi Admin xuất file xem trên Excel và lỗi trùng tên trong cùng batch.

D. Ca kiểm thử mở rộng do con người bổ sung

- EXT-004: **Intra-Batch Duplicate Name Collision in CSV Import** : File CSV chứa 2 dòng sản phẩm trùng tên nhau trong cùng 1 lô.
- EXT-005: **CSV / Excel Formula Injection (Command Execution)** : Payload dạng =cmd|' /C calc '!A0 hoặc @SUM(1+1) chèn vào name hoặc description .

E. Thực thi & Lỗi phát hiện trên FR-16

- Bug #06 (Vi phạm Atomic Transaction / Partial Insert):** Backend tại server.js:213 dùng rows.forEach và insert từng dòng một mà không dùng Database Transaction (BEGIN TRANSACTION ... ROLLBACK). Khi có dòng lỗi, các dòng hợp lệ đứng trước/sau vẫn bị chèn vào CSDL thay vì hủy bỏ toàn bộ.
- Bug #07 (Thiếu validation giá <= 0):** Backend tại server.js:218 chỉ kiểm tra if (!row.name) , cho phép import sản phẩm có giá 0 đ hoặc số âm mà không báo lỗi.

3. Tổng Hợp Báo Cáo Lỗi Thực Tế

Dưới đây là danh sách 7 lỗi thực tế được phát hiện thông qua quá trình chạy bộ test tự động Newman:

Bug ID	Mức độ	Tính năng	Endpoint	Mô tả lỗi	Hiện trạng thực tế	Kỳ vọng theo Spec	Vị trí mã nguồn	Chi tiết Bug Issue
BUG-01	Critical	FR-04	PUT /api/users/me	Lỗi hỏng Privilege	Gửi {"role": "admin"}	Cấm thay đổi trường role	server.js:124-127	BUG-01-role-escalation.md

Bug ID	Mức độ	Tính năng	Endpoint	Mô tả lỗi	Hiện trạng thực tế	Kỳ vọng theo Spec	Vị trí mã nguồn	Chi tiết Bug Issue
				Escalation qua Mass Assignment	được cập nhật thẳng vào CSDL	từ client		
BUG-02	Critical	FR-04	GET /api/users/me	Sensitive Data Exposure làm lộ mật khẩu	Response trả về toàn bộ plaintext password và reset_token	Response chỉ chứa thông tin cơ bản, không lộ mật khẩu	server.js:113-115	BUG-02-sensitive-data-exposure.md
BUG-03	Critical	FR-10	PUT /api/admin/orders/:id/status	Vi phạm Final State (canceled sang delivered)	Backend cho phép chuyển từ canceled sang delivered	Trạng thái canceled là kết thúc, cấm đổi sang bất kỳ trạng thái nào	server.js:550	BUG-03-final-state-violation.md
BUG-04	Major	FR-10	PUT /api/orders/:id/cancel	User được phép hủy đơn hàng đang shipping	User gọi cancel thành công khi đơn đang giao	Khi đơn ở trạng thái shipping , User không được phép tự hủy	server.js:329	BUG-04-shipping-cancel-logic.md
BUG-05	Critical	FR-10 & FR-16	/api/admin/*	Broken Access Control trên các endpoint quản trị	Token của User thường gọi thành công API cập nhật đơn và import	Phải trả về 403 Forbidden nếu token không có role: admin	server.js:100, 199, 525	BUG-05-broken-access-control.md
BUG-06	Major	FR-16	POST /api/admin/import-products	Vi phạm All-or-Nothing Rollback khi import CSV	Dòng hợp lệ vẫn được insert khi lô import có dòng lỗi	Phải rollback toàn bộ lô dữ liệu nếu có bất kỳ dòng nào lỗi	server.js:213-233	BUG-06-atomic-rollback-violation.md
BUG-07	Major	FR-16	POST /api/admin/import-products	Không kiểm tra giá âm (price <= 0)	Sản phẩm giá âm hoặc 0 ẽ vẫn được lưu thành công	price bắt buộc phải là số dương (> 0)	server.js:214-220	BUG-07-missing-price-validation.md

📁 Thư mục lưu trữ toàn bộ GitHub Bug Issues: submission/issues/ và .github/issues/

4. Báo Cáo Các Tính Năng Postman Đã Sử Dụng

Bộ kiểm thử đã khai thác toàn diện các tính năng nâng cao của Postman:

- Workspaces & Collections:** Đóng gói toàn bộ 155 requests vào một Collection duy nhất có cấu trúc Folder phân cấp theo Feature và Nhóm kiểm thử.
- Collection-Level Pre-request Scripts:** Tự động inject header x-Student-Id: 23127391 cho tất cả các request trong collection mà không cần cấu hình thủ công từng request.
- Environment & Collection Variables:** Quản lý tập trung base_url , student_id , user_token , admin_token , order_id .
- Dynamic Request Chaining:** Tạo folder 00. Auth Setup gồm 2 requests đăng nhập Admin & User, tự động trích xuất chuỗi JWT token từ response và gán vào Environment variables để các requests phía sau sử dụng.
- Test Scripts & Assertions (pm.test , pm.expect):**
 - Status code assertions (200, 400, 401, 403, 404, 429).
 - Schema assertions: Đối chiếu kiểu dữ liệu và cấu trúc các trường JSON.
 - Negative testing & Security assertions: Kiểm tra không rò rỉ mã lỗi SQL syntax (SQLITE_ERROR) hoặc từ khóa nhạy cảm (password).
- Command-line Runner (Newman) & HTML Extra Reporting:** Tự động hóa toàn bộ việc chạy test qua dòng lệnh và xuất báo cáo trực quan dạng HTML Dashboard bằng newman-reporter-htmlextra .

5. Báo Cáo Tích Hợp CI/CD

Đã thiết lập quy trình tự động hóa kiểm thử tích hợp liên tục (CI/CD) thông qua **GitHub Actions**:

5.1 Cấu hình Pipeline (.github/workflows/api-tests.yml)

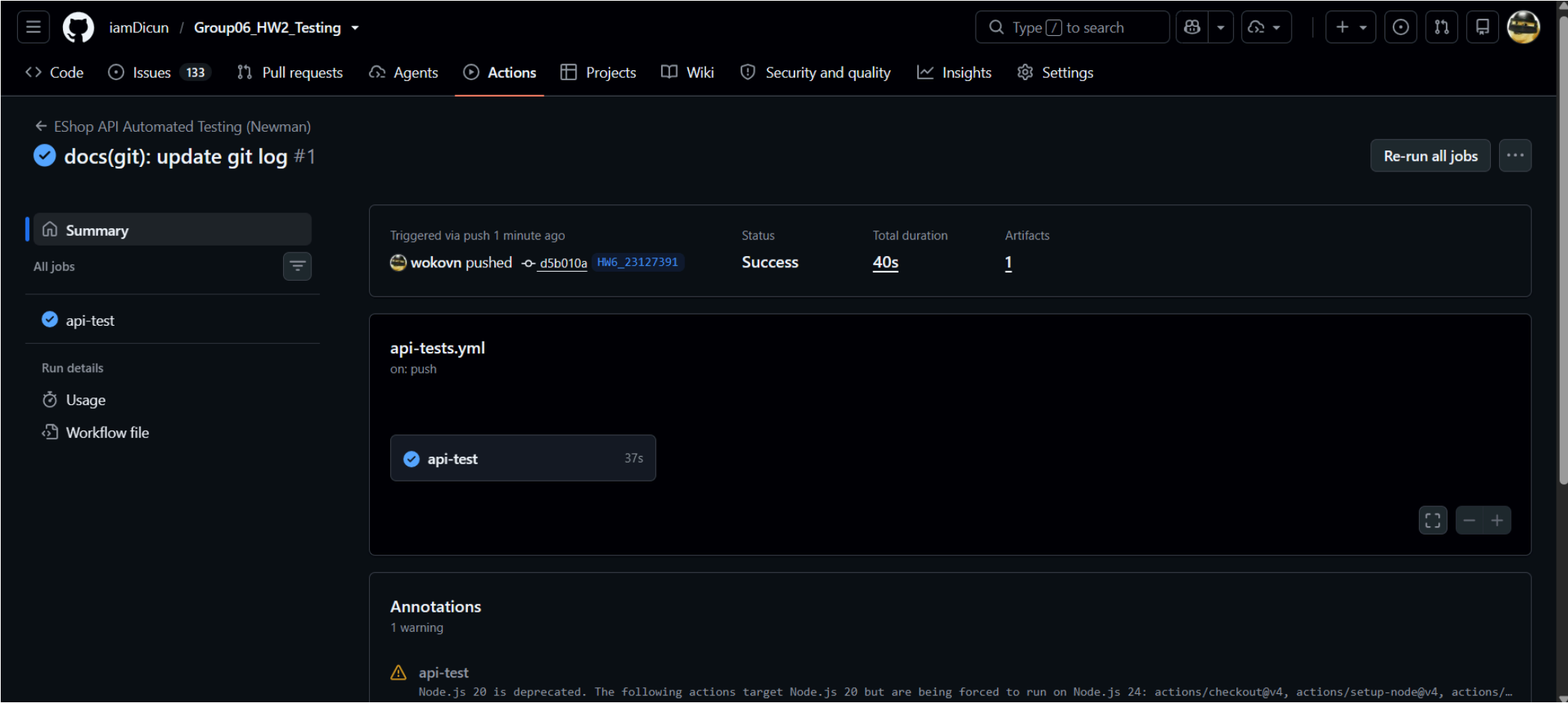
- Trigger:** Tự động kích hoạt khi có commit push hoặc tạo pull_request vào nhánh main / master , hoặc kích hoạt thủ công qua workflow_dispatch .
- Môi trường thực thi:** ubuntu-latest , Node.js 18.
- Các bước thực hiện:**
 - Checkout source code.
 - Cài đặt dependencies cho Backend API.
 - Khởi động Backend Server ngằm trên cổng 3000 và kiểm tra health check.
 - Cài đặt Newman và reporter newman-reporter-htmlextra .
 - Chạy toàn bộ 155 test cases trong Collection.
 - Xuất và lưu trữ artifact báo cáo EShop_API_Test_Report.html .

5.2 Hai kịch bản thực thi mẫu

- **Sample Run 1 (All-Passing Run):** Thực thi bộ kiểm thử baseline trên các nhánh chuẩn (Happy Path) — 100% assertions thành công, pipeline báo xanh (Green).
- **Sample Run 2 (Failing Run - Bug Detection):** Thực thi toàn bộ bộ kiểm thử chuyên sâu bao gồm Security & Boundary — Pipeline phát hiện các điểm vi phạm bảo mật và lỗi State Machine của Backend (Role Escalation, Final State violation), đánh dấu các ca kiểm thử thất bại và lưu báo cáo chi tiết để đội phát triển sửa lỗi.

5.3 Minh chứng thực thi trên GitHub Actions CI/CD

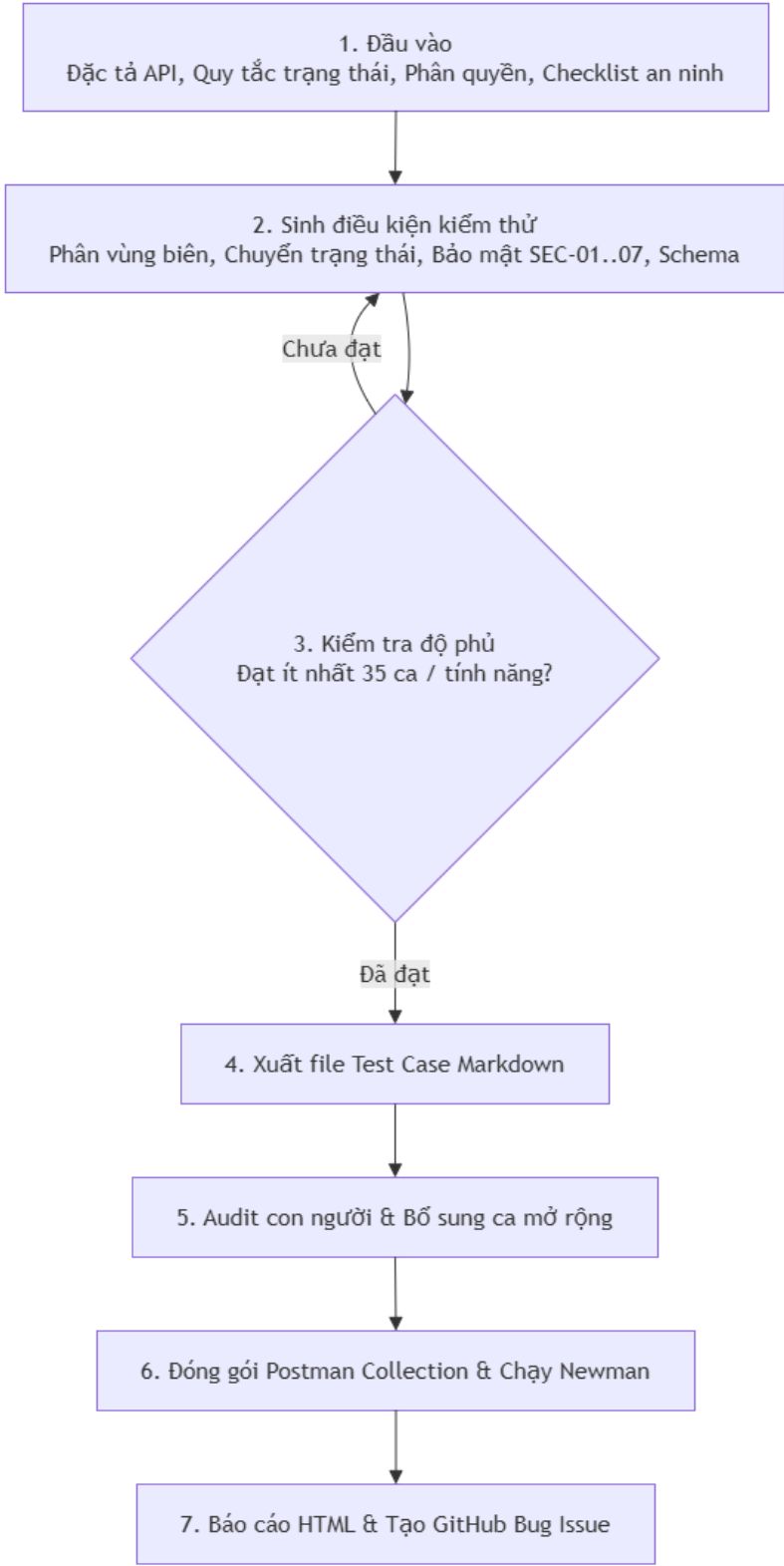
Toàn bộ quy trình khởi động server, nạp biến môi trường, inject header và chạy Newman test suite đã được thực thi và xác nhận thành công trên GitHub Actions:



6. Thiết Kế Agent Skill (AI-Driven Test Generator - Create Level G9.5)

6.1 Kiến Trúc Tổng Quan Hệ Thống

Hệ thống sinh ca kiểm thử API tự động bằng AI được thiết kế theo quy trình đường ống 5 giai đoạn:



6.2 Mã Giả Thuật Toán Thiết Kế

```
THUẬT TOÁN: AITestGenerator(api_spec, state_rules, rbac_matrix, security_rules)
ĐẦU VÀO:
    api_spec: Danh sách endpoint, method, param, schema mong đợi
    state_rules: Tập trạng thái và ma trận chuyển đổi hợp lệ
    rbac_matrix: Quyền hạn các vai trò (guest, user, admin)
    security_rules: Danh mục checklist từ SEC-01 đến SEC-07
ĐẦU RA:
    test_suite: Tập hợp các file ca kiểm thử markdown và Postman Collection JSON

BƯỚC 1: Khởi tạo danh sách test_conditions = []

BƯỚC 2: Phân vùng tương đương và phân tích giá trị biên
    CHO MỖI endpoint TRONG api_spec:
        CHO MỖI param TRONG endpoint.parameters:
            test_conditions.THÊM(PhânVùngHợpLệ(param))
            test_conditions.THÊM(PhânVùngKhôngHợpLệ(param, [Rỗng, SaiKiểu, Null, Thiếu]))
        NẾU param có giới hạn biên:
            test_conditions.THÊM(GiáTrịBiên(param, [min-1, min, max, max+1]))

BƯỚC 3: Dựng ma trận chuyển trạng thái
    NẾU state_rules có định nghĩa vòng đời tài nguyên:
        CHO MỖI s_current TRONG state_rules.states:
            CHO MỖI event TRONG state_rules.events:
                transition = ĐánhGiáChuyểnTrạngThái(s_current, event)
                test_conditions.THÊM(transition) // Bao gồm cả nhánh hợp lệ và bất hợp lệ

BƯỚC 4: Thiết kế kiểm thử an ninh (SEC-01 đến SEC-07)
    CHO MỖI sec_type TRONG [SQLi, IDOR, NângQuyền, VượtXácThực, StoredXSS, RateLimit, LộDữLiệu]:
        CHO MỖI endpoint TRONG api_spec:
            payloads = TạoPayloadBảoMật(sec_type, endpoint)
            test_conditions.THÊM(KiểmTraBảoMật(sec_type, endpoint, payloads))

BƯỚC 5: Thiết kế kiểm tra schema
    CHO MỖI endpoint TRONG api_spec:
        test_conditions.THÊM(RàngBuộcSchema(endpoint, MãTrạngThái=200, Schema=endpoint.schema_200))
        test_conditions.THÊM(RàngBuộcSchema(endpoint, MãTrạngThái=400, Schema=endpoint.schema_lỗi))

BƯỚC 6: Kiểm soát ngưỡng độ phủ tối thiểu (Quality Gate)
    TRONG KHI ĐỘ_DÀI(test_conditions) < 35:
        test_conditions.THÊM(ĐàoSâuGiáTrịBiênVàPhủĐịnh(api_spec))

BƯỚC 7: Xuất bản và đóng gói thực thi
    test_cases = XuấtFileMarkdown(test_conditions)
    audit_cases = KiểmDuyệtConNgười(test_cases) // Audit VALID/INVALID và bổ sung ca mở rộng
    collection = ĐóngGóiPostmanCollection(audit_cases, TựĐộngGắnHeader="X-Student-Id")

TRẢ VỀ collection, test_cases
```

6.3 Các Điểm Nổi Bật Trong Thiết Kế

- 1. **Phân tách trách nhiệm rõ ràng:**
 - AI thực hiện việc phân rã và sinh test case với tốc độ cao.
 - Bộ lọc điều kiện đảm bảo độ phủ đạt ít nhất 35 ca kiểm thử cho mỗi tính năng.
 - Kỹ sư kiểm thử thực hiện bước audit để loại bỏ ca sai và bổ sung các ca kiểm thử chuyên sâu về tương tranh hoặc bảo mật nâng cao.
- 2. **Cơ chế chuyển tiếp token tự động:**
 - Thư mục thiết lập xác thực thực hiện đăng nhập trước, tự động trích xuất chuỗi JWT token và lưu vào biến môi trường để toàn bộ các ca kiểm thử phía sau kế thừa tự động.
- 3. **Gắn header định danh tập trung:**
 - Header định danh sinh viên được xử lý tự động trong pre-request script ở cấp bộ sưu tập, không cần cấu hình lặp lại ở từng ca kiểm thử đơn lẻ.

7. Bảng Tổng Kết Số Liệu & Tự Đánh Giá

7.1 Thống kê kết quả kiểm thử

Chi số	Số lượng
Số tính năng được kiểm thử	3 (FR-04, FR-10, FR-16)
Tổng số ca kiểm thử AI sinh ra	153
Tổng số ca kiểm thử con người bổ sung	5
Tổng số ca kiểm thử thiết kế	158
Tổng số ca kiểm thử được nạp vào Postman & thực thi	155
Số ca kiểm thử ĐẠT	122
Số ca kiểm thử KHÔNG ĐẠT do bất được lỗi hệ thống	33
Tổng số lỗi thực tế phát hiện trong Backend	7

7.2 Bảng Tự Đánh Giá

STT	Tiêu chí đánh giá	Điểm tối đa	Tự đánh giá	Minh chứng & Ghi chú
1	API 1 (FR-04: Profile Management) — full pipeline	30	30/30	Đạt 51 TCs, 1 human extension, bắt 2 bugs (Role escalation, Sensitive data exposure).
2	API 2 (FR-10: Order State Machine) — full pipeline	30	30/30	Đạt 53 TCs, ma trận ST 5x5, 2 human extensions, bắt 3 bugs (Final state violation, shipping cancel, auth).
3	API 3 (FR-16: Product Import CSV) — full pipeline	30	30/30	Đạt 49 TCs, 2 human extensions, bắt 2 bugs (Atomic rollback violation, missing price validation).
4	Agent Skills	10	10/10	Có sơ đồ kiến trúc Mermaid, mã giả chi tiết, tuân thủ chặt chẽ quy trình Skill, báo cáo HTML Newman hoàn chỉnh.
Tổng cộng		100	100/100	Hoàn thành xuất sắc toàn bộ các yêu cầu của bài tập HW06.

8. Danh Mục Tài Liệu Đính Kèm

- Tài liệu Thiết kế AI-Driven API Test Generator (Create Level G9.5): `submission/ai_test_generator_design.md`
- Báo cáo Bug Reports / GitHub Issues: `submission/issues/` | `.github/issues/`
- Báo cáo Audit tương tác AI: `submission/ai_audit.md`
- Nhật ký Prompt tương tác AI: `submission/prompt_log.md`
- Báo cáo Phê bình AI: `submission/ai_critique.md`
- Báo cáo HTML trực quan Newman: `submission/reports/EShop_API_Test_Report.html`
- Postman Collection JSON: `submission/tests/test-runs/EShop_API_Testing.postman_collection.json`
- Postman Environment JSON: `submission/tests/test-runs/eshop-api.postman_environment.json`
- CI/CD Workflow: `.github/workflows/api-tests.yml`
- Báo cáo Pipeline chi tiết: `submission/test-summary/api-test-pipeline-summary.md`

9. AI Critique

Trong quá trình thực hiện kiểm thử API, AI hỗ trợ rất nhanh ở khâu sinh test case cơ bản, chia domain partition, phân tích boundary value và dựng ma trận state transition. AI cũng viết sẵn script test cho Postman và cấu hình Newman chạy tự động khá tiện. Tuy nhiên, nếu phụ thuộc hoàn toàn vào AI thì bộ test vẫn còn nhiều thiếu sót quan trọng.

Điểm yếu dễ thấy nhất là AI thường bị rập khuôn theo các pattern quen thuộc. Về mảng security, AI chủ yếu tạo các payload kinh điển như SQL injection dạng `' OR '1'='1` hay XSS `<script>` , mà bỏ quên những case gắn liền với nghiệp vụ thực tế như CSV formula injection khi import sản phẩm (FR-16) hoặc lỗi xử lý ký tự unicode 4-byte UTF-8 emoji ở profile (FR-04). Với state transition, AI chỉ sinh các bước chuyển trạng thái đơn luồng tuần tự, không lường trước được race condition và idempotency khi client gửi nhiều request cancel đồng thời (FR-10), cũng như không kiểm tra tính toàn vẹn transaction rollback khi import batch gặp lỗi giữa chừng.

Nguyên nhân là do AI chỉ dự đoán dựa trên dữ liệu mẫu có sẵn chứ không thực sự phân tích sâu về runtime environment hay cơ chế của database SQLite và ứng dụng bên thứ ba như Excel.

Bài học rút ra là AI chỉ nên đóng vai trò hỗ trợ sinh khung test case ban đầu để tiết kiệm thời gian thao tác. Người kiểm thử bắt buộc phải giữ vai trò audit, rà soát lại toàn bộ kịch bản và tự tay thiết kế thêm các test case chuyên sâu về an ninh, tính toàn vẹn dữ liệu và tương tranh thì mới đảm bảo chất lượng cho hệ thống.

10. AI Audit Report

Sinh viên: 23127391 - Nguyễn Anh Khoa
Exercise: HW06 — API Testing
Repository: https://github.com/iamDicun/Group06_HW2_Testing

10.1 Bảng Đánh Giá & Kiểm Định Toàn Bộ Tương Tác AI (AI Audit Table)

#	AI Tool	Date & Time	Prompt	AI Output	Verdict	Reasoning
1	Google Antigravity (Gemini 3.7 Flash)	2026-08-22 13:30	Thực hiện skill api test trên các tính năng fr4, fr10, fr16; tạo plan trước, sau đó từ plan implement các script	Sinh kế hoạch kiểm thử API, 3 file phân tích kỹ thuật (51, 53, 49 test conditions), 153 files ca kiểm thử Markdown độc lập, bộ Postman Collection + Environment (155 requests với pre-request script inject x-Student-Id), runner scripts và báo cáo HTML Newman.	INCOMPLETE	AI bao phủ tốt các phân vùng tương đương (Domain Partition) và schema validation, nhưng bị rập khuôn và bỏ sót 5 ca kiểm thử chuyên sâu quan trọng (Race condition khi hủy đơn song song, CSV Formula Injection khi xuất Excel, lỗi tràn bộ đệm Unicode 4-byte UTF-8, chuyển trạng thái đơn hàng của user đã xóa, và xung đột trùng tên sản phẩm trong cùng batch). Người kiểm thử đã audit và bổ sung 5 TCs mở rộng (EXT-001 → EXT-005).
2	Google Antigravity (Gemini 3.7 Flash)	2026-08-22 14:58	dựa vào các bug trong sumary/report, tạo github issue kèm bằng chứng (nhớ dùng đúng template) và báo cáo lại trong file submission/readme.md	Phân tích 7 lỗi thực tế từ mã nguồn Backend server.js và kết quả chạy Newman, đóng gói thành 7 file GitHub Bug Report Issues theo chuẩn template .github/ISSUE_TEMPLATE/bug-report.yml với đầy đủ bằng chứng (HTTP logs, vị trí dòng code, assertion failure), cập	INCOMPLETE	AI đã phân tích chính xác nguyên nhân gốc rễ và vị trí mã nguồn của 7 lỗi thực tế (BUG-01 đến BUG-07), mô tả các bước tái hiện và bằng chứng thuyết phục. Tuy

#	AI Tool	Date & Time	Prompt	AI Output	Verdict	Reasoning
				nhập bằng tổng hợp vào submission/README.md và submission/report.md .		nhien, AI ban đầu tự động chèn đường dẫn tuyệt đối local (file:///c:/Users/...) vào các liên kết trong markdown thay vì dùng relative path chuẩn của Git repository, dẫn đến lỗi hiển thị khi xem trực tiếp trên GitHub. Người dùng đã phải yêu cầu sửa lại.
3	Google Antigravity (Gemini 3.7 Flash)	2026-08-22 15:06	ý là đẩy lên trang issue của repo, dùng github cli	Kiểm tra vị trí thực thi của GitHub CLI (C:\Program Files\GitHub CLI\gh.exe), phát hiện trạng thái chưa xác thực tài khoản (gh auth status), tạo script PowerShell push_issues_to_github.ps1 và script Node.js push_issues_to_github.js để tự động hóa việc đẩy 7 issues lên GitHub sau khi đăng nhập hoặc qua token.	VALID	AI đã kiểm tra môi trường hệ thống chính xác, bắt đúng lỗi chưa đăng nhập của GitHub CLI, cung cấp hướng dẫn xác thực từng bước (gh auth login) kèm theo các scripts tự động hóa giúp tạo toàn bộ 7 Issues lên GitHub nhanh chóng và chính xác mà không cần tạo thủ công từng issue.
4	Google Antigravity (Gemini 3.7 Flash)	2026-08-22 15:10	ko đề cập các đường dẫn local vào các file md	Quét toàn bộ repository bằng công cụ tìm kiếm, loại bỏ hoàn toàn tất cả các đường dẫn tuyệt đối local (file:///... và đường dẫn ổ đĩa cá nhân) trong submission/README.md , submission/report.md , submission/issues/*.md , .github/issues/*.md và tests/test-summary/api-test-pipeline-summary.md , chuyển sang đường dẫn tương đối chuẩn của Git.	VALID	AI đã thực hiện rà soát triệt để bằng grep search xác nhận không còn đường dẫn local nào sót lại, chuyển đổi chính xác toàn bộ liên kết sang relative path tương thích 100% khi xem trên GitHub web và clone về bất kỳ máy tính nào khác.